

# Da Nuvem à Linha de Montagem: Modelagem de Caminhos de Ataque na Manufatura Automotiva como Infraestrutura Crítica

Henrique Hoffmann Stefanutti  
Independent Researcher  
E-mail: henrique407@outlook.com

**Resumo**—A pesquisa e a regulação de cibersegurança automotiva concentram-se no produto: a ISO/SAE 21434 e a UN R155 governam o carro, suas ECUs e seu *back end*. A fábrica que constrói o carro não é governada por nada equivalente, embora seja o ativo cuja falha interrompe a produção, deixa uma cadeia de fornecimento continental sem peças e, no evento cibernético mais caro já registrado no Reino Unido, custou a uma economia cerca de £1,9 bilhão. Este artigo trata a planta automotiva, e não o veículo, como infraestrutura crítica, e faz uma pergunta que a literatura centrada no veículo não responde: por quais caminhos um atacante efetivamente alcança a linha de montagem? Contribuímos com (i) um corpus curado de 20 incidentes publicamente reportados na manufatura automotiva entre 2017 e 2025, cada um reconstruído como um caminho em nível de ativo com rótulo explícito de confiança; (ii) o CAPM, um modelo de caminhos de ataque que atravessa TI corporativa, o plano de identidade, nuvem e SaaS, a DMZ industrial, as camadas MES/SCADA/CLP e a interface com fornecedores, instanciado como uma arquitetura de referência de 12 zonas IEC 62443, 48 ativos e 91 passos de ataque rotulados com 43 técnicas MITRE ATT&CK Enterprise e ATT&CK for ICS; (iii) uma análise probabilística que combina o ranqueamento dos  $k$  caminhos mais prováveis com uma simulação Monte Carlo de campanhas que quantifica a perda anual esperada; e (iv) um catálogo de controles mapeado para a IEC 62443-3-3 e o NIST CSF 2.0, avaliado por valor marginal, necessidade e custo-efetividade. Quatro resultados se seguem. Primeiro, o caminho de menor resistência até a parada de produção nunca toca um controlador: a rota mais provável é  $11,6\times$  mais provável do que a melhor rota que alcança o nível 2 de Purdue ou abaixo, e o corpus concorda: 55% dos incidentes causaram impacto de disponibilidade, enquanto apenas 10% teriam interagido com equipamentos abaixo do nível 3. Segundo, a capacidade de recuperação domina a prevenção em termos de perda esperada: *backups* imutáveis e testados e um modo degradado de produção ensaiado respondem pelas duas maiores reduções obtidas por um único controle, ao passo que a governança de tokens SaaS e a garantia de segurança de fornecedores são os controles que um programa maduro menos pode remover. Terceiro, o endurecimento parcial desloca o risco em vez de removê-lo: um programa voltado a cadeia de fornecimento e nuvem reduz a perda por espionagem em 73% e *aumenta* a perda por ransomware em 26%, ao empurrar um ator racional para o objetivo de disponibilidade. Quarto, medido contra quatro priorizações de referência sobre o mesmo corpus, o modelo coloca o incidente observado mediano no percentil 4,8 das rotas até sua consequência, onde heurísticas de profundidade em OT e de travessia de zonas o colocam nos percentis 95,9 e 98,9; já uma ordenação que ignora completamente a detecção tem desempenho indistinguível, de modo que o termo de contenção justifica seu lugar na estimativa de perda, e não no ranqueamento. O modelo,

o corpus, os experimentos e as figuras são publicados como artefato aberto e sem dependências externas.

**Index Terms**—infraestrutura crítica, manufatura automotiva, grafos de ataque, tecnologia operacional, MITRE ATT&CK for ICS, IEC 62443, segurança da cadeia de fornecimento, quantificação de risco

## I. INTRODUÇÃO

Uma planta moderna de montagem de veículos é um sistema ciberfísico peculiar. É grande, com dezenas de milhares de dispositivos controlados entre funilaria, pintura e montagem final, e é fortemente acoplada: a logística *just-in-time* e *just-in-sequence* elimina os estoques que absorveriam uma interrupção. E é, cada vez mais, um sistema *conectado*. Sistemas de execução da manufatura (MES) trocam ordens com plataformas de planejamento de recursos empresariais (ERP); estações de engenharia são gerenciadas pela mesma infraestrutura de gestão de *endpoints* que os notebooks do escritório; construtores de máquinas mantêm células robóticas de outro continente; análises de produção rodam em um *tenant* de nuvem pública; fornecedores recebem chamadas de peças por interfaces EDI que são, funcionalmente, um conduit para a lógica de sequenciamento da planta.

A regulação não acompanhou essa mudança. O setor automotivo investiu uma década de esforço normativo na segurança do *produto*: a ISO/SAE 21434 define a engenharia de cibersegurança para veículos rodoviários [1] e a UN R155 torna um sistema de gestão de cibersegurança certificado condição para a homologação de tipo [2]. Ambas param no portão da fábrica. Já os arcabouços que tratam de ambientes industriais, a IEC 62443 [3], [4] e o NIST SP 800-82r3 [5], são agnósticos de setor e organizam-se em torno da segmentação em zonas e conduits, um modelo cuja ameaça implícita é um adversário descendo a hierarquia de Purdue [6] rumo ao processo.

O registro empírico não corresponde a esse quadro. Entre 2017 e 2025, a produção automotiva foi interrompida repetidamente, na Renault-Nissan, na Honda, na Toyota, na Bridgestone, na Stellantis e na Jaguar Land Rover, e, em quase todos os casos, a causa reportada foi a perda de sistemas de *informação*, não a manipulação de controladores. A produção parou porque o MES foi criptografado, porque o ERP não conseguia liberar peças, porque um fornecedor Tier-1 não conseguia mais transmitir dados de entrega, ou porque a

própria vítima desconectou redes como medida de contenção. O comprometimento da Kojima Industries, fornecedora Tier-1 da Toyota, em 2022, parou 28 linhas em 14 plantas japonesas e custou cerca de 13.000 veículos de produção em um único dia [7], [8], sem qualquer alegação de que um controlador lógico programável (CLP) tenha sido tocado. O ataque de 2025 à Jaguar Land Rover interrompeu a produção global por aproximadamente cinco semanas e foi avaliado pelo Cyber Monitoring Centre do Reino Unido como um evento sistêmico de Categoria 3, com custo estimado de £1,9 bilhão para a economia britânica e mais de 5.000 organizações afetadas [9], [10].

Se é assim que as plantas efetivamente falham, modelos de risco construídos em torno da descida ao nível 0 estão otimizando a variável errada. O que o setor precisa é de um modelo de caminhos de ataque que trate o parque de TI corporativa, o plano de identidade, o *tenant* de nuvem, o perímetro SaaS, a DMZ industrial, a camada de operações e a interface com fornecedores como um *único* grafo cujos estados terminais são consequências de negócio, e que consiga ordenar as rotas desse grafo por verossimilhança e perda esperada.

#### A. Contribuições

- **C1: um corpus empírico.** Curamos 20 incidentes publicamente reportados na manufatura automotiva (2017–2025), cobrindo montadoras, fornecedores Tier-1, prestadores de serviços de engenharia e SaaS de varejo compartilhado. Cada registro traz um caminho reconstruído em nível de ativo e um rótulo explícito de confiança, de modo que a inevitável incerteza do noticiário público fique visível em vez de maquiada (section III).
- **C2: o modelo CAPM.** Definimos um modelo de caminhos de ataque entre planos com semântica probabilística explícita e o instanciamos como arquitetura de referência de uma planta de montagem: 12 zonas IEC 62443 em cinco planos, 48 ativos, 91 passos de ataque rotulados com 43 técnicas ATT&CK Enterprise e ATT&CK for ICS, e cinco consequências terminais (section IV).
- **C3: análise de caminhos, e uma comparação.** Ordenamos rotas por enumeração exata dos  $k$  caminhos mais prováveis, identificamos pontos de estrangulamento ponderados por verossimilhança e medimos o ranqueamento contra quatro priorizações de referência que representam a prática atual, pontuando todas contra o corpus (section VI).
- **C4: quantificação de risco.** Uma simulação Monte Carlo de campanhas com três perfis de ator converte a estrutura de caminhos em perda anual esperada, distribuições de tempo de parada e tempo até a consequência (section VI).
- **C5: avaliação de controles frente às normas.** Um catálogo de 17 controles, cada um mapeado para requisitos de sistema da IEC 62443-3-3 e subcategorias do NIST CSF 2.0, é avaliado por valor marginal, necessidade dentro de um programa completo e custo-efetividade, com análise de sensibilidade e de estabilidade de ranqueamento (sections VI and VII).

Todo o código, dados, experimentos e figuras são publicados como artefato sem dependências externas [11]; cada número citado neste artigo é produzido por um único *pipeline* reprodutível.

## II. FUNDAMENTAÇÃO E TRABALHOS RELACIONADOS

### A. Zonas, conduits e o modelo de Purdue

A Purdue Enterprise Reference Architecture [6] organiza ativos industriais em níveis, do processo físico (nível 0) à TI corporativa (níveis 4 e 5), e é a espinha dorsal da decomposição em zonas e conduits da IEC 62443-3-2 [3]. A IEC 62443-3-3 [4] atribui a cada zona um nível de segurança alvo (SL-T) realizado por requisitos de sistema (SR). O NIST SP 800-82r3 [5] oferece orientação compatível, e a *Industrial Control System Cyber Kill Chain* [12] descreve a estrutura em dois estágios, uma intrusão em TI seguida do desenvolvimento do ataque em ICS, observada no Stuxnet [13], na violação de Maroochy [14], nos ataques à rede elétrica ucraniana [15] e no registro histórico compilado pelo INL [16]. Essa literatura é indispensável, mas está organizada em torno da descida ao processo. Nossos resultados sugerem que, na manufatura discreta, o mecanismo dominante de perda é uma falha *lateral* de processo de negócio que nunca exige o segundo estágio.

### B. Grafos de ataque e métricas probabilísticas

Grafos de ataque formalizam a composição de passos individuais em comprometimento fim a fim [17], [18], e geradores baseados em lógica como o MulVAL [19] os tornaram tratáveis em redes reais. Métricas probabilísticas sobre grafos de ataque [20] associam verossimilhanças de sucesso a passos e as agregam ao longo dos caminhos; levantamentos [21], [22], [23] mapeiam o espaço de projeto da modelagem de ataque e defesa. Em contextos industriais, árvores e grafos de ataque foram aplicados à avaliação de vulnerabilidades em SCADA [24], [25], à avaliação de exposição em redes elétricas [26] e à análise conjunta de *safety* e *security* [27]; Cherdantseva et al. [28] revisam métodos de avaliação de risco para SCADA e apontam a escassez de parametrização empiricamente fundamentada. Trabalhos quantitativos na tradição FAIR [29], [30] fornecem o maquinário de distribuições de perda que adotamos. O que falta, e o que oferecemos, é um grafo cujos vértices abrangem *todos os cinco planos* de uma empresa de manufatura e cujos estados terminais são consequências de produção e de negócio, e não o comprometimento de um host.

### C. ATT&CK Enterprise e ATT&CK for ICS

O ATT&CK [31] e o ATT&CK for ICS [32] fornecem o vocabulário de técnicas usado neste artigo. Um caminho entre planos é *bílingue*: começa em técnicas Enterprise (T1566 Phishing, T1190 Exploit Public-Facing Application, T1078 Valid Accounts) e, se descer, continua em técnicas ICS (T0886 Remote Services, T0843 Program Download, T0831 Manipulation of Control). Rotular cada aresta com a matriz a que pertence permite medir quanto da massa de risco realista é expressável em cada vocabulário, e a maior parte dela acaba sendo Enterprise.

#### D. Cibersegurança automotiva: produto versus planta

A ISO/SAE 21434 [1] e a UN R155 [2] regulam a engenharia e a gestão de cibersegurança do veículo. Esquemas setoriais de garantia de fornecedores tratam do manuseio de informação na cadeia, e a IEC 62443-2-4 [33] especifica requisitos para prestadores de serviços de IACS. Reguladores começaram a tratar a própria manufatura como objeto: a diretiva NIS 2 da União Europeia inclui a fabricação de veículos automotores entre os setores que cobre [34], e os Estados Unidos classificam a fabricação de automóveis dentro do Setor de Manufatura Crítica [35]. A literatura acadêmica não acompanhou: não temos conhecimento de trabalho anterior que modele a *planta* automotiva como um grafo de ataque entre planos, calibre-o contra o próprio registro de incidentes do setor e o utilize para ordenar controles na linguagem da IEC 62443 e do NIST CSF. A afirmação está limitada pela busca descrita no artefato e pela literatura alcançável por ela. A section III começa por estabelecer esse registro.

### III. A PLANTA COMO INFRAESTRUTURA CRÍTICA: UM CORPUS DE INCIDENTES, 2017–2025

#### A. Construção do corpus

Reunimos um corpus de incidentes de cibersegurança publicamente reportados cuja vítima é uma montadora, um fornecedor de componentes, um prestador de serviços de engenharia do setor ou uma plataforma compartilhada da qual dependem a produção ou a distribuição de veículos. Um incidente foi incluído quando (i) a vítima ou fontes confiáveis identificaram o nexu automotivo, (ii) ao menos uma consequência foi descrita com detalhe suficiente para ser classificada, e (iii) havia duas fontes independentes ou uma divulgação da própria vítima. Cobrimos todo o espaço de consequências (disponibilidade, confidencialidade de dados de engenharia e exposição de dados pessoais) em vez de restringir o corpus a paradas de produção, porque o modelo precisa expressar tanto as rotas que os atores *não* tomaram quanto as que tomaram. O resultado são 20 incidentes: dois em 2017, dois em 2020, cinco em 2022, quatro em 2023, três em 2024 e quatro em 2025 [36], [37], [38], [7], [8], [39], [40], [41], [42], [43], [44], [45], [46], [47], [9], [10], [48], [49]. O registro completo, incluindo as URLs de origem de cada incidente e a data de consulta, é publicado junto ao artefato [11].

Cada registro traz uma reconstrução do incidente como sequência de ativos da arquitetura de referência da section IV, acompanhada de um rótulo de confiança: **alta** quando a sequência decorre da divulgação da própria vítima; **média** quando várias fontes independentes concordam; **baixa** quando o vetor de entrada é reportado mas a propagação interna é inferida; **disputada** quando as fontes divergem sobre o vetor de entrada; **tentativa** quando a campanha foi interrompida antes do impacto; e **parcial** quando a consequência observada está em parte fora do escopo centrado na planta. Os rótulos respondem a um problema estrutural desta área: vítimas de incidentes na manufatura raramente publicam detalhe forense, e um modelo que escondesse a incerteza resultante atrás de

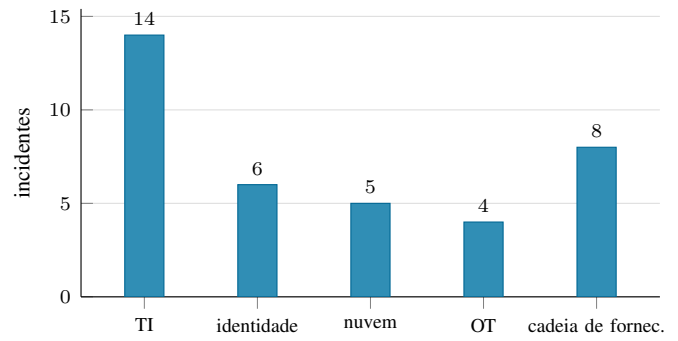


Figura 1. Planos atravessados pelos 20 incidentes do corpus (2017–2025). Apenas dois incidentes teriam interagido com equipamentos abaixo do nível 3 de Purdue.

sequências de nós aparentemente seguras seria pior do que um que a expõe. A table I lista o corpus.

#### B. Achados descritivos

Três propriedades do corpus moldam o restante do artigo.

**A disponibilidade domina.** Onze dos vinte incidentes tiveram a parada de produção como consequência primária (55%, IC de Wilson 95% 34–74%); cinco causaram roubo de dados de engenharia ou corporativos e quatro expuseram dados pessoais de clientes. Vinte incidentes sustentam apenas intervalos largos, e por isso reportamos intervalos de escore de Wilson em todo o texto: nesse tamanho amostral a aproximação normal é inutilizável perto dos extremos, e essas proporções devem ser lidas pela direção que indicam, não por seu segundo dígito.

**A cadeia de fornecimento é uma superfície de ataque de primeira classe.** Oito dos vinte incidentes (40%, IC 22–61%) atravessaram o plano da cadeia de fornecimento, seja porque a vítima *era* um fornecedor cuja falha se propagou a uma montadora (Kojima/Toyota, Yanfeng/Stellantis, Sensata, MKS Instruments), seja porque o ponto de falha foi uma plataforma compartilhada fora do controle da montadora (CDK Global, a plataforma SaaS por trás da divulgação da Stellantis em 2025).

**A tecnologia operacional raramente é o alvo.** Apenas dois dos vinte incidentes (10%, IC 3–30%) teriam interagido com equipamentos abaixo do nível 3 de Purdue, e em ambos os casos a interação foi malware autopropagante criptografando hosts de produção baseados em Windows, e não uma manipulação deliberada do controle. Nenhum incidente do corpus envolveu uma carga de programa adversarial documentada em um controlador. A fig. 1 mostra a distribuição dos planos atravessados.

#### C. Três estudos de caso

**Kojima Industries e Toyota (2022): o acoplamento como amplificador.** Um ransomware em um fornecedor Tier-1 de componentes de interior criptografou os sistemas usados para receber pedidos e confirmar entregas. A Toyota, operando em *just-in-time* com estoques mínimos, suspendeu 28 linhas em 14 plantas por um dia, perdendo aproximadamente 13.000

Tabela I

O CORPUS DE INCIDENTES EXPRESSO NO MODELO DE REFERÊNCIA. “PCT.” É O PERCENTIL DO CAMINHO RECONSTRUÍDO ENTRE TODOS OS CAMINHOS MODELADOS QUE ALCANÇAM A MESMA CONSEQUÊNCIA (MENOR É MAIS PROVÁVEL).

| ID     | Ano  | Vítima                     | Impacto        | Conf.     | $L(\pi)$ | Pct. |
|--------|------|----------------------------|----------------|-----------|----------|------|
| INC-01 | 2017 | Renault-Nissan             | parada         | média     | 0.00228  | 4.8  |
| INC-02 | 2017 | Honda                      | parada         | baixa     | 0.00228  | 4.8  |
| INC-03 | 2020 | Honda                      | parada         | baixa     | 0.00091  | 16.7 |
| INC-04 | 2022 | Toyota (via Kojima Industr | parada         | alta      | 0.04678  | 0.2  |
| INC-05 | 2022 | Denso                      | eng.           | média     | 0.06126  | 1.9  |
| INC-06 | 2022 | Bridgestone Americas       | parada         | baixa     | 0.00079  | 17.8 |
| INC-07 | 2022 | Continental                | eng.           | média     | 0.01742  | 7.7  |
| INC-08 | 2020 | Tesla (Gigafactory Nevada) | parada         | tentativa | 0.00225  | 5.1  |
| INC-09 | 2023 | Toyota (T-Connect / G-Link | dados pessoais | alta      | 0.02916  | 14.3 |
| INC-10 | 2024 | Volkswagen Group (Cariad)  | dados pessoais | alta      | 0.02916  | 14.3 |
| INC-11 | 2024 | CDK Global                 | parada         | parcial   | 0.03150  | 0.7  |
| INC-12 | 2024 | Hyundai Motor Europe       | eng.           | baixa     | 0.01512  | 9.6  |
| INC-13 | 2023 | Nissan Oceania             | eng.           | média     | 0.01475  | 11.5 |
| INC-14 | 2023 | Yanfeng (Stellantis suppli | parada         | média     | 0.04678  | 0.2  |
| INC-15 | 2025 | Tata Technologies          | eng.           | média     | 0.06126  | 1.9  |
| INC-16 | 2025 | Sensata Technologies       | parada         | média     | 0.04678  | 0.2  |
| INC-17 | 2025 | Stellantis                 | dados pessoais | alta      | 0.08400  | 4.8  |
| INC-18 | 2025 | Jaguar Land Rover          | parada         | disputada | 0.04078  | 0.4  |
| INC-19 | 2022 | Toyota (T-Connect)         | dados pessoais | média     | 0.01225  | 19.0 |
| INC-20 | 2023 | MKS Instruments            | parada         | média     | 0.04678  | 0.2  |

veículos de produção [7], [8]. Os parques de TI e OT da própria montadora permaneceram, por todos os relatos públicos, intocados. O mecanismo de transmissão não foi um conduit de rede, mas um conduit *de negócio*: o fluxo de dados de chamada de peças e de entrega do qual depende o sequenciamento da produção. Em termos do modelo, todo o caminho tem três passos e nunca sai dos níveis 4 e 5.

**Jaguar Land Rover (2025): perda sistêmica a partir de um evento no lado de TI.** A produção parou nas plantas da empresa a partir de 31 de agosto de 2025, com retomada gradual desde o início de outubro. A JLR não divulgou o vetor de acesso inicial; o noticiário apontou tanto para a exploração de software corporativo exposto à Internet quanto para credenciais de terceiros que nunca foram revogadas, e por isso rotulamos a reconstrução como *disputada*, codificando a hipótese reportada e mantendo a alternativa como um caminho distinto do modelo. O que não é disputado é a consequência: o Cyber Monitoring Centre classificou o evento como sistêmico de Categoria 3, com custo econômico estimado em £1,9 bilhão e mais de 5.000 organizações afetadas [9], [10]. Dois aspectos importam para a modelagem. Primeiro, a duração da parada, cerca de cinco semanas, é uma ordem de grandeza maior do que as paradas causadas por vermes em 2017, e é isso que converte um incidente fabril em um evento econômico nacional. Segundo, a perda foi suportada muito além da vítima: um ecossistema de fornecedores sem qualquer capacidade de influenciar os controles da JLR absorveu parte expressiva dela.

**Cariad, Toyota Connected e o perímetro SaaS (2022–2025): o plano de nuvem.** Armazenamento em nuvem mal configurado expôs dados de aproximadamente 800.000 veículos elétricos na subsidiária de software da Volkswagen [44]; uma configuração incorreta expôs registros de localização

de 2,15 milhões de clientes da Toyota ao longo de uma década [43]; uma chave de acesso publicada em repositório público de código expôs outros 296.000 [48]; e, em 2025, uma plataforma SaaS de terceiros foi a rota até dados de clientes da Stellantis [47]. Nenhum deles parou uma linha. Eles importam aqui porque são rotas baratas e de alto retorno que competem pelo mesmo esforço adversarial que a disrupção de produção. Como mostra a section VI, é essa a razão pela qual endurecê-las altera a *composição* das consequências que uma planta deve esperar.

#### IV. O MODELO CAPM

##### A. Definição formal

Uma instância do CAPM é um multigrafo dirigido e rotulado

$$G = (V, E, Z, \tau, p, \delta, c), \quad (1)$$

em que  $V$  é um conjunto de ativos particionado por  $Z$  em zonas IEC 62443 e  $E \subseteq V \times V$  é um conjunto de passos de ataque atômicos.  $V$  contém um vértice de entrada distinguido  $v_0$  (o ator externo) e um conjunto  $I \subset V$  de vértices terminais de *impacto*, que representam consequências de negócio. Cada aresta  $e$  carrega:

- $\tau(e)$ , uma técnica MITRE ATT&CK (Enterprise ou ICS);
- $p(e) \in (0, 1]$ , a probabilidade de o passo ter sucesso dado que o ator detém o ativo de origem;
- $\delta(e) \in [0, 1)$ , a probabilidade de o passo ser detectado *e contido* antes que o ator possa avançar a partir dele;
- $c(e) > 0$ , o esforço esperado do ator em horas.

Um caminho  $\pi = \langle e_1, \dots, e_n \rangle$  de  $v_0$  até um impacto tem verossimilhança

$$L(\pi) = \prod_{i=1}^n p(e_i) (1 - \delta(e_i)), \quad (2)$$

a probabilidade de que todos os passos tenham sucesso e nenhum seja contido. Tomando logaritmos, a eq. (2) transforma-se no peso aditivo

$$w(e) = -\log(p(e)(1 - \delta(e))) \geq 0, \quad (3)$$

de modo que o caminho mais provável é um caminho mínimo sob  $w$  e os  $k$  caminhos mais prováveis seguem do algoritmo de Yen. Essa é a transformação logarítmica padrão da análise probabilística de grafos de ataque [20]; ela mantém o ranqueamento exato e evita subfluxo numérico em caminhos longos.

Um portfólio de controles  $P$  atua sobre as arestas por dois fatores. Uma *mitigação*  $m_P(e) \in [0, 1]$  remove uma fração da verossimilhança de sucesso do passo, e um *ganho de detecção*  $u_P(e) \in [0, 1]$  converte parte da massa não detectada restante em contenção:

$$p_P(e) = p(e)(1 - m_P(e)), \quad (4)$$

$$\delta_P(e) = \delta(e) + (1 - \delta(e))u_P(e). \quad (5)$$

Quando vários controles se aplicam ao mesmo passo, seus efeitos compõem-se multiplicativamente sobre o resíduo,  $1 - \prod_j (1 - m_j)$ , o que codifica retornos decrescentes ao empilhar controles sobrepostos.

Duas métricas estruturais decorrem daí. Para um conjunto ordenado de caminhos  $\Pi$ , a *criticidade* de um vértice  $v$  é a fração da massa agregada de verossimilhança que passa por ele,

$$\kappa(v) = \frac{\sum_{\pi \in \Pi, v \in \pi} L(\pi)}{\sum_{\pi \in \Pi} L(\pi)}, \quad (6)$$

e a mesma quantidade calculada sobre arestas fornece a *criticidade de conduit*, que identifica as fronteiras cujo endurecimento remove mais risco agregado.  $\kappa$  é o análogo, em grafos de ataque, da centralidade de intermediação por fluxo, ponderada por plausibilidade e não por contagem. A distinção importa: como mostra a section VI, contar caminhos e ponderá-los por verossimilhança levam a prioridades opostas.

### B. Arquitetura de referência

A fig. 2 apresenta a planta instanciada. Além da pilha clássica de Purdue, modelamos dois planos que os diagramas de Purdue omitem e um que eles externalizam:

- o **plano de identidade** (Active Directory local, provedor de identidade em nuvem, confiança de federação, gestão de acesso privilegiado e credenciais dormentes de terceiros), que é onde o comprometimento de TI se converte em comprometimento da planta;
- o **plano de nuvem** (plano de controle do *tenant*, armazenamento de objetos e data lake, pipeline CI/CD, *back end* de veículo conectado) mais o SaaS de terceiros que a empresa não opera;
- o **plano da cadeia de fornecimento** (parques de TI de Tier-1, a interface EDI/JIT, o acesso remoto de construtores de máquinas, o canal de atualização de software e firmware de OT e a mídia removível).

A instância compreende 12 zonas, 48 ativos e 91 passos de ataque extraídos de 43 técnicas ATT&CK, sendo 70 passos

rotulados com técnicas Enterprise e 21 com técnicas ICS; 72 dos 91 passos cruzam uma fronteira de zona e são, portanto, conduits no sentido da IEC 62443. Cinco consequências terminais são modeladas: parada de produção, degradação silenciosa de qualidade, perda de função de segurança, roubo de dados de engenharia e vazamento de dados pessoais de clientes.

### C. Modelo de consequência e de campanha

Cada impacto  $i \in I$  carrega um modelo de consequência: uma distribuição triangular da duração da parada, uma taxa de perda por hora de produção parada e uma distribuição triangular de custos fixos de resposta, perícia, obrigações regulatórias e notificação. Atravessar um ativo *inibidor de recuperação* (a infraestrutura de backup, a plataforma de gestão de *endpoints*, o controlador de domínio OT) multiplica a parada amostrada, refletindo a diferença empírica entre uma parada de fim de semana e uma de cinco semanas. Controles do lado da consequência (backups offline testados, um modo degradado manual ensaiado) a encurtam.

O ranqueamento de caminhos responde para onde um ator provavelmente irá, mas não com que frequência uma planta perde dinheiro, porque uma campanha é um processo sequencial sob orçamento de tempo no qual o defensor pode intervir a qualquer passo. Por isso simulamos campanhas. Um ator parte de  $v_0$  com um orçamento (720 horas de atividade prática, por padrão) e seleciona repetidamente, entre todos os passos disponíveis a partir dos ativos que detém, aquele que minimiza

$$w(e) + d(\text{dst}(e)) + \varepsilon, \quad \varepsilon \sim \mathcal{N}(0, \sigma^2), \quad (7)$$

em que  $d(v)$  é a resistência ponderada por utilidade de  $v$  até os objetivos do ator, o mínimo, sobre os impactos, da resistência residual do caminho menos o logaritmo da utilidade que o ator atribui àquele impacto, e  $\sigma$  é um termo de ruído de política que representa o planejamento imperfeito do adversário. O passo consome seu esforço, tem sucesso com probabilidade  $p_P(e)$  e é contido com probabilidade  $\delta_P(e)$ ; a contenção encerra a campanha. Modelamos três perfis de ator por seus vetores de utilidade sobre as consequências: *ransomware* (parada de produção dominante, roubo de dados como alavanca de dupla extorsão), *espionagem* (dados de engenharia dominantes) e *sabotagem* (segurança e qualidade dominantes). A perda anual esperada é  $\text{ALE} = \lambda \cdot \mathbb{E}[\text{perda por campanha}]$  para uma frequência de campanhas  $\lambda$ , com  $\lambda = 1,5$  por planta-ano na linha de base e variada na section VI.

### D. Controles e mapeamento normativo

O catálogo contém 17 controles, cada um caracterizado por sua mitigação, ganho de detecção, efeito de recuperação e um índice relativo de custo anualizado, e cada um mapeado para os requisitos de sistema da IEC 62443-3-3 [4] e as subcategorias do NIST CSF 2.0 [50] que implementa (table II). É esse mapeamento que torna o resultado quantitativo acionável: uma planta não compra “um fator de mitigação de 0,55”, ela financia um projeto de fronteira de zona SR 5.1 ou um programa de autenticação resistente a phishing PR.AA-03. Cinco cenários nomeados são avaliados:  $S_1$  identidade primeiro,  $S_2$  zonas e

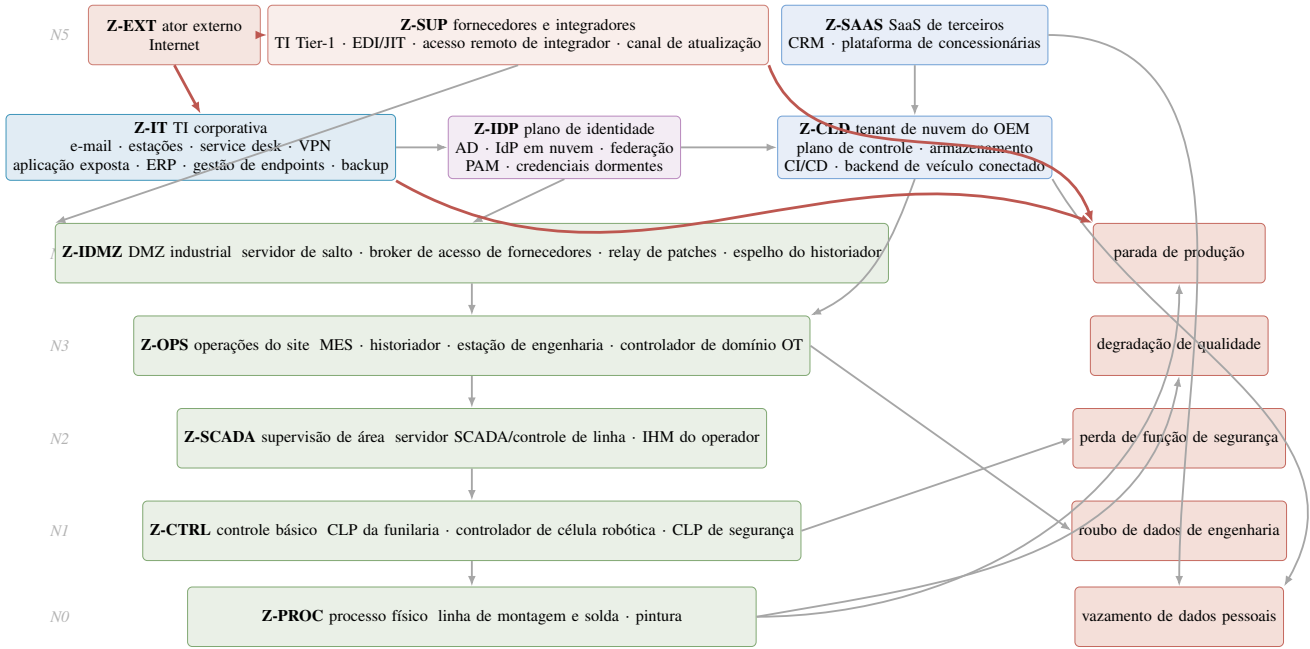


Figura 2. Arquitetura de referência da planta de montagem modelada: 12 zonas IEC 62443 em cinco planos, 48 ativos e 91 passos de ataque. As setas escuras marcam as duas rotas de maior verossimilhança até a parada de produção encontradas na section VI; ambas terminam em sistemas de negócio e logística, sem entrar nas camadas de controle. As setas cinzas mostram os demais conduits principais.

conduits IEC 62443,  $S_3$  cadeia de fornecimento e nuvem,  $S_4$  detectar e recuperar, e  $S_5$  o programa completo, contra a linha de base  $S_0$ .

### E. Parametrização

Os parâmetros das arestas são estimativas pontuais elicitadas de especialista, e o material suplementar lista cada uma delas com a banda em que se situa, os controles que atuam sobre ela, os incidentes do corpus que a sustentam e a razão pela qual o passo é modelado. Elas são ancoradas de quatro formas. As probabilidades de acesso inicial são ordenadas pela frequência relativa dos vetores de entrada correspondentes no corpus e no noticiário público sobre intrusões na manufatura. As probabilidades de movimentação lateral e de descida refletem as precondições técnicas do passo: se ele exige apenas credenciais válidas, um exploit ou presença física. As probabilidades de detecção codificam a maturidade de monitoramento que se pode supor em uma planta de porte médio *antes* da implantação de qualquer controle do catálogo, razão pela qual  $S_0$  é descrito como linha de base e não como configuração desprotegida. Os parâmetros de consequência são ancorados em resultados reportados: a parada de um dia em 14 plantas da Toyota em um extremo da distribuição de duração e as cinco semanas da Jaguar Land Rover no outro. A taxa de perda por hora parada e os custos fixos de resposta são os parâmetros mais grosseiros do modelo, e os primeiros que uma planta deveria substituir por seus próprios números.

Não afirmamos que essas estimativas pontuais sejam os parâmetros verdadeiros de qualquer planta específica. A resposta certa a parâmetros elicitados é testar o que eles sustentam: a section VI relata, portanto, como as conclusões se movem sob

perturbação sistemática e trata como não sustentada qualquer conclusão que não sobreviva a ela.

## V. DESENHO EXPERIMENTAL

Seis experimentos rodam sobre a mesma instância do grafo. O **E1** enumera todos os caminhos sem repetição de vértices, de no máximo doze passos, do vértice de entrada até uma consequência, ordena-os pela eq. (2) e mede a profundidade que cada caminho alcança na hierarquia de Purdue. O **E2** reconcilia o corpus com o modelo: se cada incidente reconstruído é um caminho do modelo, onde esse caminho cai no ranqueamento do próprio modelo e como o modelo se comporta sob a ablação descrita adiante. O **E3** calcula a criticidade de vértices e conduits. O **E4** executa a simulação de campanhas para três perfis de ator nos seis cenários de controles. O **E5** avalia cada controle de três maneiras: seu valor *marginal* quando implantado sozinho sobre a linha de base, sua *necessidade*, medida como a perda que retorna quando ele é retirado do programa completo, e sua custo-efetividade; em seguida constrói um portfólio guloso adicionando repetidamente o controle com melhor redução de risco por unidade de custo. O **E6** testa robustez: a estabilidade do ranqueamento de caminhos sob perturbação log-normal multiplicativa de todos os  $p$  e  $\delta$  ( $\sigma = 0,35$ , 200 réplicas), varreduras um-a-um de eficácia de detecção, frequência de campanhas e orçamento do ator, e a estabilidade do ranqueamento de controles em doze grafos perturbados.

O **E7** mede o modelo contra as alternativas. Ele ordena o mesmo conjunto de caminhos com quatro heurísticas de referência que representam a prática atual, pontuando todas as ordenações, inclusive a do CAPM, contra a mesma verdade

Tabela II  
CATÁLOGO DE CONTROLES MAPEADO PARA OS REQUISITOS DE SISTEMA DA IEC 62443-3-3 E PARA AS SUBCATEGORIAS DO NIST CSF 2.0.

| ID  | Controle                                                                 | IEC 62443-3-3                  | NIST CSF 2.0                 |
|-----|--------------------------------------------------------------------------|--------------------------------|------------------------------|
| C01 | MFA resistente a phishing para acesso remoto e privilegiado              | SR 1.1; SR 1.2; SR 1.5; SR 1.7 | PR.AA-02; PR.AA-03           |
| C02 | Acesso condicional e conformidade de dispositivo                         | SR 1.13; SR 2.6                | PR.AA-05                     |
| C03 | Camadas administrativas e estações de acesso privilegiado                | SR 1.1; SR 2.1; SR 1.11        | PR.AA-05; PR.PS-01           |
| C04 | Acesso remoto de fornecedores intermediado e just-in-time                | SR 1.13; SR 2.6; SR 6.1        | PR.AA-05; GV.SC-07           |
| C05 | Segmentação TI/OT com DMZ industrial                                     | SR 5.1; SR 5.2; SR 5.3         | PR.IR-01                     |
| C06 | Lista de permissão de aplicações e controle de mídia em hosts OT         | SR 2.3; SR 3.2                 | PR.PS-05                     |
| C07 | Deteção em endpoint com resposta monitorada 24/7                         | SR 6.2; SR 3.2                 | DE.CM-01; DE.CM-09; RS.MA-01 |
| C08 | Backups imutáveis, offline e testados (TI e OT)                          | SR 7.3; SR 7.4                 | PR.DS-11; RC.RP-01           |
| C09 | Controle de mudança e integridade de programa em controladores           | SR 3.4; SR 3.8; SR 7.6         | PR.PS-01; DE.CM-09           |
| C10 | Gestão de superfície de ataque e correção acelerada de serviços expostos | SR 7.2; SR 3.10                | ID.RA-01; PR.PS-02           |
| C11 | Governança de SaaS e de tokens OAuth                                     | SR 1.9; SR 2.1                 | PR.AA-05; GV.SC-06           |
| C12 | Higiene de identidades e revogação de credenciais dormentes              | SR 1.3; SR 1.5                 | PR.AA-01; GV.SC-07           |
| C13 | Monitoramento contínuo de rede OT e inventário de ativos                 | SR 6.2; SR 7.8                 | ID.AM-01; DE.CM-01           |
| C14 | Garantia de segurança de fornecedores e telemetria contratual            | SR 1.13; SR 6.1                | GV.SC-01; GV.SC-04; GV.SC-08 |
| C15 | Verificação de identidade no service desk e risco de insider             | SR 1.1; SR 2.10                | PR.AA-01; GV.RR-02           |
| C16 | Gestão de postura de nuvem e de exposição de dados                       | SR 4.1; SR 4.3                 | PR.DS-01; PR.DS-10; ID.RA-01 |
| C17 | Resiliência operacional: buffers, fallback manual e modo degradado       | SR 7.1; SR 7.4                 | RC.RP-01; RC.RP-05; GV.SC-08 |

de campo: o percentil em que os incidentes do corpus caem entre os caminhos que alcançam a mesma consequência. As referências são B1, menor número de passos, o proxy clássico de grafos de ataque; B2, apenas explorabilidade, que multiplica as probabilidades de sucesso dos passos e ignora detecção e contenção, como faz a pontuação centrada em vulnerabilidades; B3, maior profundidade em OT, a ordenação implícita da prática centrada em zonas; e B4, maior número de fronteiras de zona atravessadas, o reflexo centrado em segmentação. As ordenações são comparadas por um teste exato de Wilcoxon bilateral sobre os percentis pareados e pelo  $\tau_b$  de Kendall sobre todo o conjunto de caminhos. Uma

referência baseada em magnitude de consequência foi omitida por construção: como os caminhos são pontuados dentro do conjunto que alcança a mesma consequência, tal ordenação é constante dentro de cada conjunto de comparação e colapsa em seu critério de desempate.

Os experimentos Monte Carlo usam 20.000 campanhas por configuração com sementes fixas; o *pipeline* completo roda em cerca de dez minutos em um núcleo de uma máquina comum e requer apenas um interpretador CPython 3.9+. Como o corpus informou a construção do grafo, a cobertura simples seria uma verificação de consistência, e não uma validação. O E2 acrescenta, portanto, uma ablação *leave-one-out*: para

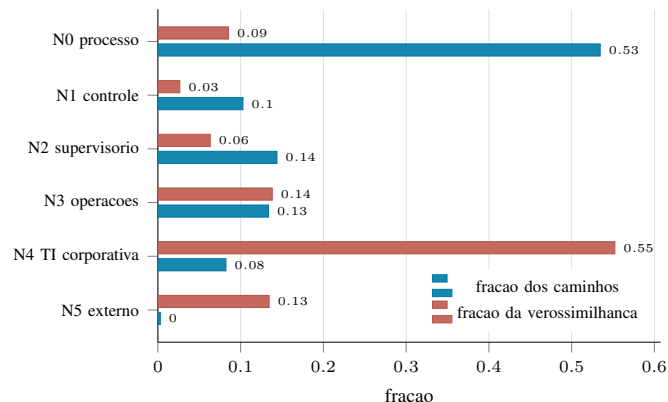


Figura 3. Onde o risco esta. Para cada nível de Purdue, a fracao dos caminhos modelados que o alcanam como ponto mais profundo (barras a esquerda) contra a fracao da verossimilhança agregada que esses caminhos carregam (barras a direita). A maioria dos caminhos desce fundo; a maior parte do risco plausível nao.

cada incidente, toda aresta cuja *única* evidência de apoio é aquele incidente é removida e o incidente é reavaliado contra o modelo reduzido. Um caminho que sobrevive é expresso por estrutura que generaliza entre casos, e não por passos ajustados a um caso único.

## VI. RESULTADOS

### A. F1: o caminho de menor resistência contorna as camadas de controle

A arquitetura de referência admite 681 caminhos de ataque distintos de no máximo doze passos: 455 alcançam a parada de produção, 118 a degradação de qualidade, 52 o roubo de dados de engenharia, 35 uma consequência de segurança e 21 o vazamento de dados pessoais. Contados ingenuamente, a planta parece um problema clássico de OT: 379 dos 455 caminhos de produção (83%) passam pelo nível 2 de Purdue ou abaixo.

A fig. 3 mostra o que acontece quando esses caminhos são ponderados por quão prováveis são. Os caminhos que nunca descem abaixo do nível 4 são 8,5% do grafo (58 de 681) e carregam 68,7% da verossimilhança agregada; os 532 caminhos que alcançam o nível 2 ou abaixo são 78% do grafo e carregam 17,5%. Contar caminhos e ponderá-los por plausibilidade ordenam os problemas da planta em direções opostas.

A ponderação por verossimilhança inverte essa conclusão. A fig. 4 e a table III apresentam as dez rotas mais prováveis até a parada de produção. O caminho mais provável tem três passos e verossimilhança de 0,047: *ator externo* → *TI do fornecedor Tier-1* → *interface EDI/JIT* → *parada de produção*. O segundo, com 0,041, é *ator externo* → *aplicação corporativa exposta à Internet* → *ERP* → *parada de produção*. O caminho mais provável que de fato alcança o nível 2 ou abaixo tem verossimilhança de 0,0040. A rota mais provável até uma linha parada é 11,6× mais provável do que a rota mais provável que toca o controle supervisorio ou algo abaixo dele.

O perfil de técnicas acompanha esse resultado (fig. 5). Ordenadas pela fração da verossimilhança agregada dos caminhos, as técnicas líderes são T1567.002 (exfiltração para armazenamento em nuvem, 0,35), T1210 (exploração de serviços remotos, 0,25), T1078 (contas válidas, 0,23), T1190 (exploração de aplicação exposta, 0,22), T1133 (serviços remotos externos, 0,21) e T1486 (dados criptografados para impacto, 0,17). A primeira técnica ICS aparece bem abaixo no ranqueamento. Dos 91 passos modelados, 21 são técnicas ICS, e ainda assim eles carregam uma fração pequena da massa plausível de risco: o ATT&CK for ICS permanece essencial para descrever o que um ator *poderia* fazer ao processo, mas é o ATT&CK Enterprise que descreve o que para a linha.

### B. F2: o modelo concorda com o registro

Todos os 20 incidentes do corpus são expressáveis como caminhos do modelo de referência. Mais informativo é onde esses caminhos caem no ranqueamento do próprio modelo: o incidente reconstruído mediano situa-se no percentil 4,8 de todos os caminhos modelados que alcançam a mesma consequência, e todos os 20 estão no quartil superior. As rotas que de fato ocorreram são as rotas que o modelo considera mais prováveis, comportamento que um instrumento de priorização utilizável precisa exibir.

Sob a ablação *leave-one-out*, 13 dos 20 incidentes (65%) permanecem expressáveis após a remoção de todo passo que existe unicamente por conta de sua própria evidência, subindo para 75% quando apenas passos de propagação interna são removidos e o acesso inicial é mantido. As falhas são informativas: são quase todas passos de *acesso inicial*: o download drive-by por trás da intrusão na Continental, o recrutamento de insider tentado na Tesla, o comprometimento da plataforma de concessionárias na CDK, o abuso de token SaaS por trás da divulgação da Stellantis, o segredo de nuvem exposto em repositório público. Vetores de entrada neste setor são idiossincráticos e cada nova campanha tende a introduzir um; o que generaliza é o que acontece depois. Essa assimetria tem leitura defensiva direta, retomada na section VII.

### C. F3: os pontos de estrangulamento são sistemas de negócio

A fig. 6 ordena os ativos pela fração da massa agregada de verossimilhança que passa por eles. Excluindo os próprios vértices de consequência, os principais pontos de estrangulamento são a estação de engenharia (0,27), a estação de trabalho do funcionário (0,23), o gateway de VPN de acesso remoto (0,16), o parque de TI do fornecedor Tier-1 (0,15) e o núcleo de ERP (0,14). No nível de conduit, as transições de maior criticidade são *ator* → *fornecedor Tier-1* via T1566 (0,15), *ator* → *aplicação exposta à Internet* via T1190 (0,11) e *ator* → *VPN* via T1133 (0,11).

A estação de engenharia merece destaque. É o único ativo que aparece com alta criticidade em *ambos* os regimes: é a dobradiça da descida ao controle (todo caminho de carga de programa passa por ela) e é alcançável a partir do parque corporativo por gestão de *endpoints*, exploração em rede plana, acesso remoto de fornecedores, mídia removível e acesso de

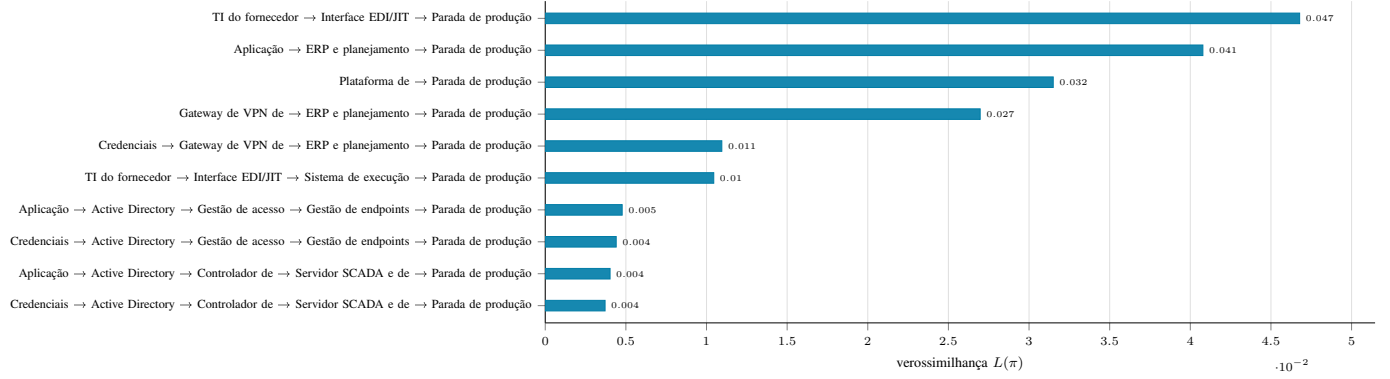


Figura 4. Os dez caminhos mais prováveis até a parada de produção na linha de base  $S_0$ . As rotas de maior verossimilhança terminam em sistemas de negócio e logística, não em controladores.

Tabela III  
OS DEZ CAMINHOS DE ATAQUE MAIS PROVÁVEIS ATÉ A PARADA DE PRODUÇÃO NA CONFIGURAÇÃO DE LINHA DE BASE  $S_0$ . NENHUM DELES EXIGE ALCANÇAR O NÍVEL 1 DE PURDUE.

| #  | $L(\pi)$ | Passos | Purdue min. | Caminho                                                                                                                                                                                         |
|----|----------|--------|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1  | 0.0468   | 3      | 5           | Ator externo → TI do fornecedor Tier-1 → Interface EDI/JIT de pedidos e logística → Parada de produção                                                                                          |
| 2  | 0.0408   | 3      | 4           | Ator externo → Aplicação corporativa exposta à Internet → ERP e planejamento de produção → Parada de produção                                                                                   |
| 3  | 0.0315   | 2      | 4           | Ator externo → Plataforma de gestão de concessionárias → Parada de produção                                                                                                                     |
| 4  | 0.0270   | 3      | 4           | Ator externo → Gateway de VPN de acesso remoto → ERP e planejamento de produção → Parada de produção                                                                                            |
| 5  | 0.0109   | 4      | 4           | Ator externo → Credenciais dormentes de terceiros → Gateway de VPN de acesso remoto → ERP e planejamento de produção → Parada de produção                                                       |
| 6  | 0.0104   | 4      | 3           | Ator externo → TI do fornecedor Tier-1 → Interface EDI/JIT de pedidos e logística → Sistema de execução da manufatura (MES) → Parada de produção                                                |
| 7  | 0.0048   | 5      | 4           | Ator externo → Aplicação corporativa exposta à Internet → Active Directory local (tier 0) → Gestão de acesso privilegiado → Gestão de endpoints e distribuição de software → Parada de produção |
| 8  | 0.0044   | 5      | 4           | Ator externo → Credenciais dormentes de terceiros → Active Directory local (tier 0) → Gestão de acesso privilegiado → Gestão de endpoints e distribuição de software → Parada de produção       |
| 9  | 0.0040   | 5      | 2           | Ator externo → Aplicação corporativa exposta à Internet → Active Directory local (tier 0) → Controlador de domínio OT → Servidor SCADA e de controle de linha → Parada de produção              |
| 10 | 0.0037   | 5      | 2           | Ator externo → Credenciais dormentes de terceiros → Active Directory local (tier 0) → Controlador de domínio OT → Servidor SCADA e de controle de linha → Parada de produção                    |

insider. Em termos da IEC 62443, é um ativo de nível 3 rotineiramente administrado a partir do nível 4, uma zona cujo SL-T é minado pelos conduits de que seus administradores precisam.

#### D. F4: risco por cenário e o efeito de deslocamento

A fig. 8 e a table V apresentam os resultados das campanhas. Na linha de base contra o perfil de ransomware, 9,8% das campanhas alcançam uma consequência, 7,7% causam parada de produção e 90,2% são contidas antes de qualquer consequência. A perda média é de US\$ 31,7 milhões por campanha e US\$ 323 milhões condicionada a impacto, com percentil 95 de US\$ 733 milhões; o tempo médio entre a primeira ação e a primeira consequência é de 35 horas. Com  $\lambda = 1,5$  campanhas por planta-ano, isso equivale a

uma perda anual esperada de US\$ 47,6 milhões. Toda cifra monetária desta seção é uma propriedade da arquitetura de referência sob os parâmetros enunciados acima, e não uma previsão para qualquer fabricante real; os valores devem ser lidos comparativamente, entre cenários e entre controles, e a varredura sobre  $\lambda$  na fig. 11 mostra quanto do valor absoluto repousa sobre uma suposição de direcionamento.

Dois resultados de cenário precisam de enunciado exato.

**Deteção e recuperação dominam.** O  $S_4$  (deteção em endpoint com resposta monitorada, backups imutáveis e testados, gestão de superfície de ataque e resiliência operacional) reduz a perda anual em 64,6%, para US\$ 16,9 milhões. O programa completo  $S_5$  a reduz em 92,9%, para US\$ 3,4 milhões. Em contraste, o  $S_1$  (identidade primeiro) e o  $S_2$

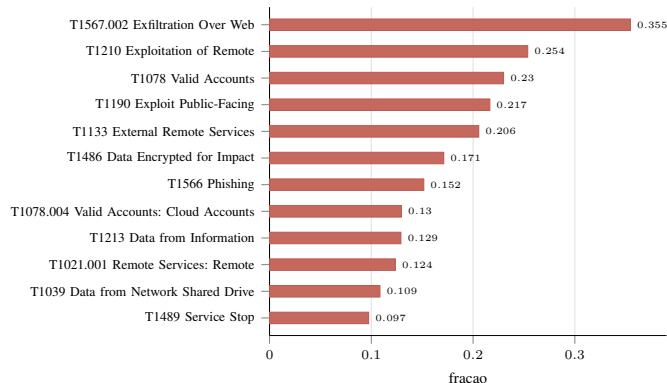


Figura 5. Técnicas MITRE ATT&CK ordenadas pela fração da verossimilhança agregada dos caminhos que passa por elas (matrizes Enterprise e ICS combinadas).

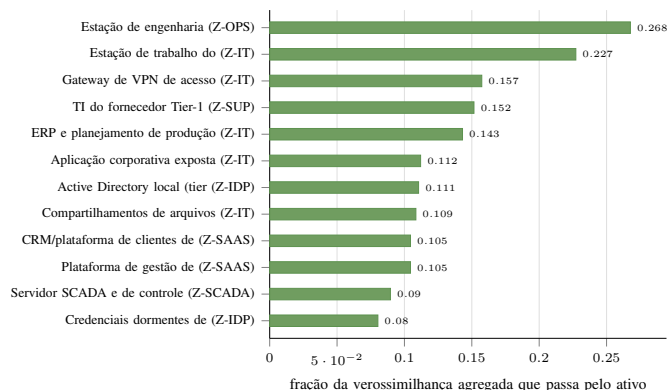


Figura 6. Pontos de estrangulamento da arquitetura de referência, ponderados por verossimilhança.

(zonas e conduits IEC 62443) movem a perda da linha de base em cerca de 1% cada. O endurecimento de identidade e a segmentação são o que torna caras as rotas de OT, de modo que o resultado nada diz contra eles. Ele diz onde a perda esperada se encontra hoje.

**O endurecimento parcial desloca o risco.** O  $S_3$  (cadeia de fornecimento e nuvem) reduz a perda anual do perfil de espionagem de US\$ 22,0 milhões para US\$ 5,9 milhões, uma redução de 73%, enquanto *eleva* a do perfil de ransomware em 26,3%, de US\$ 47,6 milhões para US\$ 60,1 milhões. O mecanismo é visível nos traços da simulação: na linha de base, um ator sensível à utilidade frequentemente desvia para objetivos baratos de roubo de dados e é muitas vezes contido durante esses desvios; remover os objetivos baratos concentra a campanha no objetivo mais danoso. A fig. 7 mostra o mecanismo diretamente. Ir do  $S_0$  para o  $S_3$  leva a probabilidade de uma campanha terminar em vazamento de dados de clientes de 0,019 para 0,0003 e em roubo de dados de engenharia de 0,0050 para 0,0008, enquanto a probabilidade de parada de produção sobe de 0,077 para 0,103. O orçamento que o ator deixa de gastar em objetivos baratos é gasto no objetivo caro.

Um deslocamento de risco desse tipo é invisível para

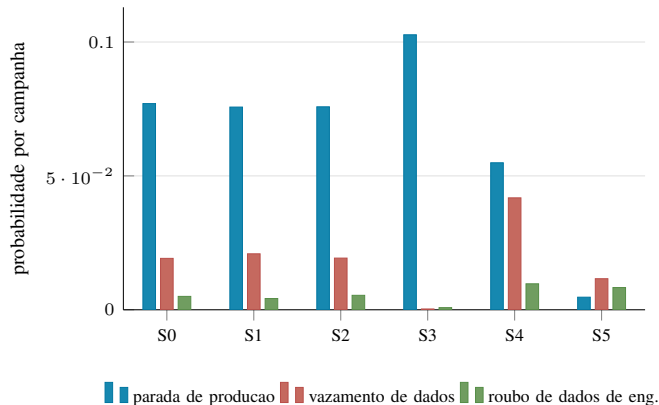


Figura 7. Composição das consequências por campanha em cada cenário de controles, perfil de ransomware de grande porte. O  $S_3$  remove os desfechos baratos de roubo de dados e a probabilidade de parada de produção sobe: o efeito de deslocamento da seção V.I.D tornado visível.

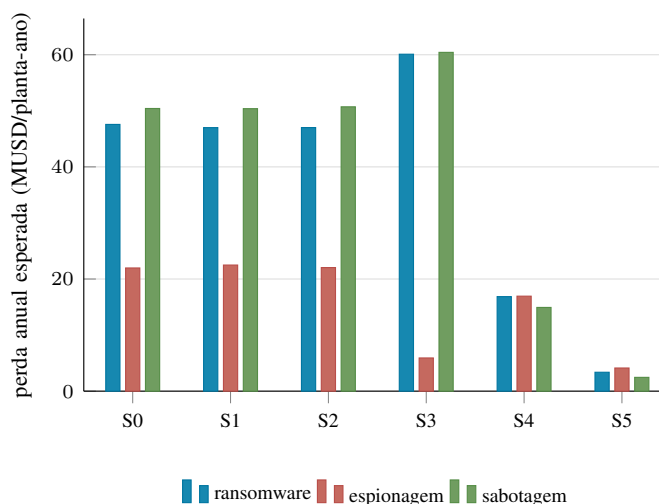


Figura 8. Perda anual esperada por cenário de controles e perfil de ator. O cenário  $S_3$  reduz fortemente o risco de espionagem enquanto *aumenta* o de ransomware: endurecer as rotas baratas de roubo de dados desloca o ator racional para o objetivo de disponibilidade.

avaliações de controle que pontuam cada objetivo isoladamente, e recomenda sequenciar o programa de modo que a proteção da disponibilidade não fique atrás da proteção da confidencialidade.

#### E. F5: quais controles importam, e em que sentido

Implantados isoladamente sobre a linha de base, apenas quatro controles produzem redução material da perda anual contra o perfil de ransomware: resiliência operacional  $C_{17}$  (US\$ 20,2 milhões), backups imutáveis e testados  $C_{08}$  (US\$ 18,3 milhões), gestão de superfície de ataque  $C_{10}$  (US\$ 5,5 milhões) e detecção monitorada em endpoint  $C_{07}$  (US\$ 4,9 milhões). Todos os demais controles, tomados isoladamente, valem quase nada. Cada um continua funcionando nos passos que cobre; o grafo simplesmente oferece rotas redundantes ao redor deles. As maiores reduções, por um único controle, da

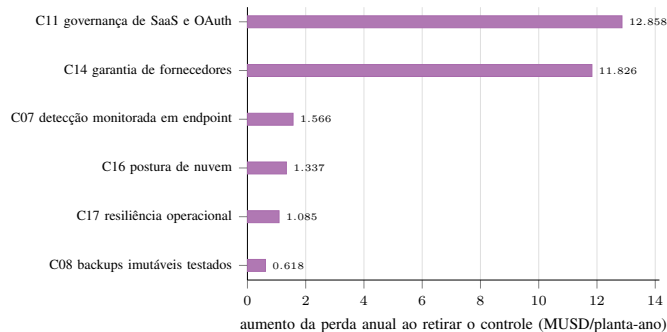


Figura 9. Necessidade de cada controle dentro do programa completo  $S_5$ : a perda anual que retorna quando apenas aquele controle é retirado.

verossimilhança da rota líder são a garantia de fornecedores  $C_{14}$  (-12,8%) e a resiliência operacional  $C_{17}$  (-10,0%); um controle pode dobrar substancialmente a rota principal e ainda assim quase não mover a perda esperada.

A necessidade conta a história complementar (fig. 9). Retirar um único controle do programa completo  $S_5$  custa mais caro no caso da governança de SaaS e de tokens OAuth  $C_{11}$  (+US\$ 12,9 milhões) e da garantia de segurança de fornecedores  $C_{14}$  (+US\$ 11,8 milhões), seguidas pela detecção monitorada  $C_{07}$  (+US\$ 1,6 milhão) e pela gestão de postura de nuvem  $C_{16}$  (+US\$ 1,3 milhão). Os controles que nada valem sozinhos são os que um programa maduro não pode remover: são as paredes que fecham as rotas para as quais os demais controles empurram o ator. A análise marginal isolada, a forma padrão de justificar investimentos de segurança, subestima esses controles de maneira sistemática.

A seleção gulosa por redução de risco por unidade de custo produz, para o perfil de ransomware, a sequência  $C_{08}$  (backups),  $C_{17}$  (resiliência operacional),  $C_{11}$  (governança de SaaS),  $C_{10}$  (gestão de superfície de ataque),  $C_{14}$  (garantia de fornecedores) e  $C_{02}$  (acesso condicional), levando a perda anual de US\$ 47,6 milhões para US\$ 5,5 milhões com 31 das 91 unidades de índice de custo que o catálogo completo consumiria, uma redução de 88%, equivalente a 95% da redução obtida pelo programa completo de 17 controles por cerca de um terço de seu custo (fig. 10, table VI). A ordenação depende do perfil: contra o perfil de sabotagem, os controles do lado de OT que mal aparecem no caso de ransomware entram na fronteira muito antes, o que é a forma quantitativa da observação de que as prioridades de controle de uma planta dependem de quem se espera que a ataque.

#### F. F6: o que sobrevive à perturbação

Sob perturbação log-normal multiplicativa de todos os parâmetros de probabilidade ( $\sigma = 0,35$ , 200 réplicas), o ranqueamento dos dez principais caminhos até a parada de produção retém, em média, 65,7% de seus membros, e o caminho mais provável permanece em primeiro lugar em 36% das réplicas. O achado *qualitativo* é muito mais estável do que a ordenação: em todas as réplicas, as rotas líderes continuam sendo rotas curtas, do lado de TI e da cadeia de fornecimento, porque

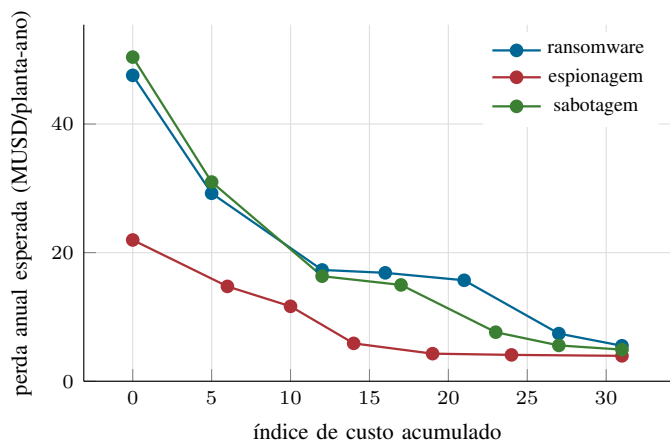


Figura 10. Fronteira eficiente obtida por seleção gulosa sobre a redução marginal de risco por unidade de custo, para cada perfil de ator.

as rotas profundas de OT são mais longas e as penalidades multiplicativas se acumulam com o comprimento. Conclusões sobre qual *classe* de rota domina são sustentadas; afirmações sobre a ordenação precisa dentro do top dez não são, e não as fazemos.

Varreduras um-a-um (fig. 11) identificam a eficácia de detecção como o parâmetro dominante: reduzir pela metade todos os  $\delta$  eleva a perda anual da linha de base de US\$ 47,6 milhões para US\$ 176,8 milhões, um fator de 3,7, enquanto aumentá-la em 50% reduz a perda para US\$ 14,2 milhões. A perda anual é linear na frequência de campanhas por construção, de modo que a faixa de US\$ 15,9 milhões a US\$ 126,8 milhões para  $\lambda \in [0,5; 4,0]$  mede o custo da incerteza sobre o direcionamento, e não sobre a planta. Nos doze grafos perturbados, o ranqueamento de controles por custo-efetividade é liderado de forma consistente por  $C_{08}$  (posição média 2,3),  $C_{17}$  (3,3) e  $C_{10}$  (3,8); a garantia de fornecedores  $C_{14}$  e a governança de SaaS  $C_{11}$  apresentam alta variância (melhor posição 1, pior posição 17), refletindo sensibilidade genuína a quão expostas são as interfaces de fornecedores e de SaaS de cada planta.

#### G. F7: frente às priorizações que uma planta usa hoje

A table IV e a fig. 12 pontuam o CAPM e as quatro referências sobre a mesma verdade de campo. O CAPM coloca o incidente mediano do corpus no percentil 4,8 dos caminhos que alcançam sua consequência, com os 20 incidentes dentro do quartil superior e 14 dentro do decil superior.

As duas heurísticas que codificam a intuição industrial convencional falham gravemente. Ordenar por profundidade na hierarquia de Purdue (B3) coloca o incidente observado mediano no percentil 95,9, perto do *fim* de sua própria lista, com 4 dos 20 incidentes no quartil superior e  $\tau_b = -0,08$  de Kendall contra o CAPM. Ordenar pelo número de fronteiras de zona atravessadas (B4) é ainda pior: percentil mediano 98,9, nenhum incidente no quartil superior e efeito rank-biserial de  $-1,00$ , o que significa que o CAPM ranqueou mais alto todos os vinte incidentes. Ambas as diferenças são significativas com

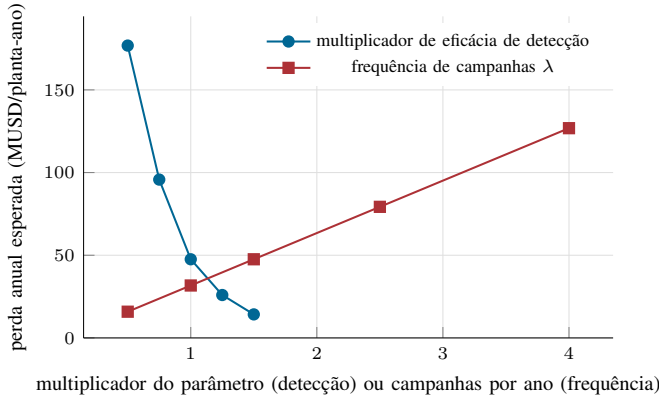


Figura 11. Sensibilidade um-a-um da perda anual esperada. Reduzir a eficácia de detecção pela metade multiplica a perda da linha de base por 3.7; a resposta à frequência de campanhas é linear por construção.

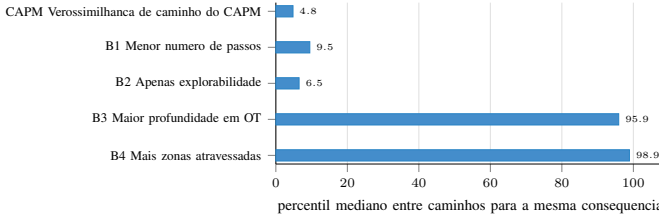


Figura 12. Percentil mediano dos incidentes do corpus sob cada priorização (menor e melhor). As heurísticas centradas em segmentação e em profundidade colocam as rotas que de fato ocorreram perto do fim de suas listas.

$p < 10^{-4}$ . Uma planta que prioriza os caminhos que descem mais fundo, ou que atravessam mais zonas, está priorizando quase exatamente as rotas que os incidentes do setor não tomaram.

Dois resultados são mais desconfortáveis para o modelo. A ordenação por menor número de passos (B1) é uma concorrente fraca, porém real: percentil mediano 9,5, 18 dos 20 incidentes no quartil superior, e o CAPM a supera de forma significativa ( $p = 0,010$ ), mas não dramática: boa parte da vantagem do CAPM sobre B1 vem de preferir caminhos curtos, o que B1 faz por construção. E a ordenação apenas por explorabilidade (B2), que descarta inteiramente o termo de contenção  $\delta$ , é estatisticamente indistinguível do CAPM completo neste critério (mediana 6,5 contra 4,8;  $p = 0,99$ ; efeito rank-biserial +0,02). Reportamos o resultado porque ele se sustenta: com a evidência disponível, modelar detecção e contenção não melhora de forma mensurável a ordenação das rotas. Seu valor está em outro ponto do modelo, e é grande. A fig. 11 mostra a eficácia de detecção como o parâmetro mais influente da estimativa de perda, movendo a perda anual por um fator de 3,7 na faixa varrida. A afirmação defensável é, portanto, mais estreita do que se gostaria: o termo de contenção justifica seu lugar na quantificação de risco, e não no ranqueamento de caminhos.

## VII. DISCUSSÃO

### A. Os conduits que importam são processos de negócio

A IEC 62443 pede que a organização defina zonas e os conduits entre elas, e os profissionais leem instintivamente “conduit” como “caminho de rede”. Os resultados defendem uma leitura mais ampla. A rota mais provável até uma linha parada no nosso modelo, e a rota efetivamente tomada no incidente de cadeia de fornecimento mais consequente do corpus, é um conduit de *fluxo de dados*: o fluxo de chamadas de peças, instruções de sequenciamento e confirmações de entrega entre um fornecedor e a planta. Ele não transporta tráfego de controle, não cruza nenhum firewall de OT e é invisível para um modelo de zonas centrado em ativos. Ainda assim, sua interrupção para a produção tão eficazmente quanto a falha de um controlador. O mesmo vale para o acoplamento ERP–MES. Uma avaliação de risco 62443 que enumere apenas conduits técnicos não atribuirá a esses fluxos nenhum SL-T nem qualquer requisito de monitoramento.

A recomendação prática é estender o exercício de zonas e conduits com um inventário de conduits de *dependência de produção*: para cada fluxo de dados de negócio do qual dependem o sequenciamento, a disponibilidade de peças ou a expedição, registrar a zona de origem, o proprietário (frequentemente um terceiro), o tempo máximo tolerável de interrupção e o *fallback* manual. No nosso modelo é exatamente isso que representa o controle  $C_{17}$ , e ele é o segundo melhor investimento isolado disponível.

### B. Recuperação é um controle de segurança

As duas maiores reduções de perda esperada por um único controle são os backups offline testados e um modo degradado de produção ensaiado, ambos atuando sobre a consequência e não sobre a verossimilhança. Isso não é um artefato dos nossos parâmetros, mas uma propriedade estrutural de um sistema fortemente acoplado com distribuição de parada de cauda pesada: quando a perda média é dominada pela cauda, encurtar a cauda supera reduzir a probabilidade de entrar nela. O registro empírico aponta na mesma direção. As paradas por vermes em 2017 duraram um fim de semana; a parada da JLR em 2025 durou cinco semanas e se tornou um evento econômico nacional [9]. A diferença entre esses dois desfechos é de recuperação, não de prevenção.

Um corolário de governança: a capacidade de recuperação deveria ser auditada com o mesmo rigor dos controles preventivos, o que na prática significa evidência de exercícios de restauração que incluam artefatos de OT (projetos de controladores, imagens de IHM, bancos de dados do MES, receitas e conjuntos de parâmetros) e evidência de que a planta consegue operar em modo degradado sem seu MES por um período definido.

### C. A priorização depende do adversário, e programas parciais deslocam risco

A fronteira gulosa difere entre perfis de ator, e o  $S_3$  reduz a perda por espionagem enquanto eleva a perda por ransomware. Ambos os achados desaconselham apresentar uma única lista

Tabela IV

O CAPM FRENTE A PRIORIZACOES DE REFERENCIA. CADA ORDENACAO CLASSIFICA OS MESMOS 681 CAMINHOS MODELADOS; O ESCORE E O PERCENTIL EM QUE OS 20 INCIDENTES DO CORPUS CAEM ENTRE OS CAMINHOS QUE ALCANCAM A MESMA CONSEQUENCIA (MENOR E MELHOR).  $p$  E UM TESTE EXATO DE WILCOXON BILATERAL CONTRA O CAPM SOBRE OS PERCENTIS PAREADOS.

|      | Ordenacao                          | Pct. mediano | Pct. medio | Top 10% | Top 25% | $\tau_b$ | $p$               | $r$   |
|------|------------------------------------|--------------|------------|---------|---------|----------|-------------------|-------|
| CAPM | Verossimilhanca de caminho do CAPM | 4.8          | 6.8        | 14/20   | 20/20   | n/a      | n/a               | n/a   |
| B1   | Menor numero de passos             | 9.5          | 11.3       | 11/20   | 18/20   | +0.76    | 0.010             | -0.65 |
| B2   | Apenas explorabilidade             | 6.5          | 7.9        | 15/20   | 19/20   | +0.78    | 0.992             | +0.02 |
| B3   | Maior profundidade em OT           | 95.9         | 76.9       | 2/20    | 4/20    | -0.08    | $\$ < 10^{-4} \$$ | -0.97 |
| B4   | Mais zonas atravessadas            | 98.9         | 96.7       | 0/20    | 0/20    | -0.64    | $\$ < 10^{-4} \$$ | -1.00 |

ordenada de controles como universalmente ótima. Uma planta que modele apenas um adversário precificará sistematicamente mal os controles que importam para outro, e um programa que endureça primeiro as rotas orientadas à confidencialidade pode aumentar, no intervalo, o risco de disponibilidade. A posição defensável é sequenciar os investimentos de modo que os controles do lado da consequência, que são agnósticos ao objetivo porque atuam depois do sucesso do ator, estejam em vigor antes do endurecimento seletivo das rotas de um objetivo específico.

#### D. A entrada é idiossincrática; a propagação não é

A ablação *leave-one-out* mostrou que os incidentes deixam de ser reproduzíveis sobretudo em seu primeiro passo. Cada campanha neste setor parece chegar por sua própria porta: um download drive-by, uma ligação de vishing para o service desk, uma aplicação corporativa exposta, uma conta dormente de terceirizado, um token OAuth em uma integração SaaS, um segredo em repositório público, um insider a quem se oferece um milhão de dólares. A propagação interna, em contraste, reutiliza um repertório pequeno. Um programa de segurança que gaste seu esforço marginal tentando enumerar vetores de entrada luta contra uma cauda longa; o mesmo esforço aplicado ao repertório de propagação (camadas de credenciais, higiene da gestão de *endpoints*, a estação de engenharia, o acoplamento ERP–MES, a recuperação) defende contra portas que ainda não foram inventadas. O argumento é antigo, mas o corpus e a ablação lhe dão uma medição concreta e específica do setor.

#### E. Implicações setoriais

Dois incidentes do corpus, Kojima/Toyota e CDK Global, compartilham uma estrutura que nenhum modelo de risco de empresa isolada captura: a falha de uma organização propagou-se a centenas ou milhares de outras por uma dependência compartilhada. A JLR estende o padrão à escala nacional, com mais de 5.000 organizações afetadas [9], [10]. Arcabouços regulatórios começam a reconhecer a fabricação de veículos como sujeita a obrigações de infraestrutura crítica [34], [35], mas obrigações impostas a entidades individuais não endereçam, por si só, o risco de concentração em plataformas compartilhadas. A extensão natural do CAPM é um grafo em nível setorial no qual montadoras, fornecedores Tier- $n$  e plataformas compartilhadas são vértices e o acoplamento

*just-in-time* é um parâmetro explícito de amplificação; o modelo, como especificado, já trata a interface com fornecedores como plano de primeira classe, de modo que a extensão é mecânica, não conceitual.

#### F. Aplicando o modelo em uma planta

O fluxo de trabalho pretendido para o profissional é: (1) substituir o conjunto de ativos de referência pelo inventário da própria planta, preservando os cinco planos; (2) marcar cada aresta como presente, ausente ou condicionalmente presente, já que a ausência de uma aresta é uma afirmação de segurança e registrá-la converte uma suposição em uma declaração auditável; (3) relicitar  $p$ ,  $\delta$  e esforço com os engenheiros da planta, usando resultados de exercícios *purple team* quando disponíveis; (4) rodar o *pipeline*; (5) ler as saídas como uma agenda ordenada de conduits e controles, expressa em termos de IEC 62443 e NIST CSF. O valor do exercício está menos nos números absolutos de perda, que herdaram toda a incerteza de suas entradas, do que na ordenação relativa e, sobretudo, nas divergências que ele revela entre o que uma planta acredita sobre sua segmentação e o que seu próprio inventário de conduits implica.

### VIII. AMEAÇAS À VALIDADE

**Validade de construto.** As probabilidades das arestas são estimativas pontuais elicitadas de especialista, e não frequências medidas; nenhum conjunto de dados público sustenta taxas de sucesso por técnica em ambientes de OT automotivos. Mitigamos isso publicando todos os parâmetros, reportando resultados de perturbação e restringindo nossas afirmações às que sobrevivem à perturbação. O modelo de consequência supõe que as perdas se acumulem linearmente com a duração da parada, o que subestima efeitos não lineares como o descumprimento de datas de lançamento e penalidades contratuais.

**Validade interna.** A política de campanha é uma busca best-first ruidosa sob um vetor de utilidade. Atores reais são menos consistentes e às vezes mais criativos; em particular, o efeito de deslocamento da section VI depende da suposição de que um ator redireciona racionalmente seu alvo quando objetivos baratos são removidos. Os passos são tratados como condicionalmente independentes dados os ativos detidos pelo ator, o que ignora falhas correlacionadas, como uma única credencial que destrava vários conduits ao mesmo tempo; isso

enviesa para baixo as verossimilhanças das rotas centradas em identidade.

**Validade empírica.** O corpus é um registro do que foi *reportado*, não do que aconteceu. Vítimas de incidentes na manufatura raramente publicam detalhe forense, de modo que a propagação interna é inferida na maioria dos registros e normalmente apenas o vetor de entrada e a consequência são atestados; os rótulos de confiança marcam qual é qual, e quatro registros são rotulados como baixa ou disputada por essa razão. Vetores que não geram obrigação de divulgação nem parada visível estão estruturalmente sub-representados, e é nessa direção que o corpus mais provavelmente engana: espionagem silenciosa e campanhas malsucedidas são quase invisíveis nele. Afirmarões deste artigo sobre frequência descrevem, portanto, o corpus, e não o setor. **Validade externa.** O corpus apoia-se em noticiário público, enviesado para incidentes grandes o bastante para perturbar a produção ou disparar divulgação, e para Europa, América do Norte e Japão. Intrusões silenciosas, defesas bem-sucedidas e incidentes em fornecedores Tier- $n$  menores estão sistematicamente sub-representados, de modo que o modelo é calibrado sobre a parte visível da distribuição. A arquitetura de referência descreve uma planta de montagem de veículos com alta automação; uma estampa, uma fábrica de células de bateria ou uma instalação de baixa automação exigiriam outra instância, embora esperemos que a estrutura de cinco planos se transfira.

**Validade de comparação.** As referências do F7 são nossas próprias operacionalizações de heurísticas de prática, e não métodos publicados, e um defensor da priorização centrada em zonas poderia argumentar, com razão, que ninguém ordena caminhos apenas por profundidade. A comparação deve ser lida como um teste da *suposição* que essas práticas codificam, e não como um benchmark contra uma ferramenta específica. O corpus é também a evidência que informou a estrutura do grafo, o que favorece o CAPM e o B2 frente ao B3 e ao B4; a ablação leave-one-out do F2 limita o quanto.

**Validade de conclusão.** As estimativas Monte Carlo usam 20.000 campanhas por configuração com sementes fixas; diferenças menores que cerca de 3% na perda anual entre configurações vizinhas não devem ser interpretadas. O corpus, com 20 incidentes, sustenta proporções descritivas com intervalos de confiança largos; por isso reportamos contagens ao lado dos percentuais em todo o texto.

**Ética.** O corpus é construído exclusivamente a partir de noticiário público, e o modelo opera no nível de técnicas e conduits, nunca de exploits: nenhum detalhe de vulnerabilidade, *payload* ou procedimento que auxilie um atacante aparece no artigo ou no artefato publicado. A arquitetura de referência é genérica e não descreve nenhuma planta identificável.

## IX. CONCLUSÃO E TRABALHOS FUTUROS

Propusemo-nos a modelar a planta automotiva, e não o veículo, como infraestrutura crítica, e a responder a uma pergunta que a literatura centrada no veículo não endereça: quais caminhos efetivamente alcançam a linha de montagem. A resposta, tanto no registro empírico quanto no modelo, é

que a rota mais curta até uma linha parada passa por sistemas de negócio e logística: a interface EDI de um fornecedor, uma aplicação corporativa exposta à Internet, um núcleo de ERP, um MES. Não passa por um controlador. A rota mais provável até a parada de produção é  $11,6\times$  mais provável do que a rota mais provável que alcança o controle supervisorio ou abaixo; 55% dos incidentes do corpus causaram impacto de disponibilidade, enquanto apenas 10% teriam interagido com equipamentos abaixo do nível 3. A eficácia de detecção é o parâmetro mais relevante, a capacidade de recuperação é a classe de investimento isolada mais valiosa, os controles que parecem inúteis isoladamente revelam-se os menos removíveis em um programa maduro, e o endurecimento parcial pode deslocar risco de um objetivo para outro mais danoso.

Medido contra as priorizações que uma planta usa hoje, o modelo coloca o incidente observado mediano perto do topo de sua lista onde as heurísticas centradas em profundidade e em segmentação o colocam perto do fim; uma ordenação que ignora completamente a contenção, porém, vai tão bem quanto o modelo completo, o que limita o que se pode afirmar sobre o termo de contenção.

Quatro extensões decorrem diretamente. Primeiro, *calibração*: substituir probabilidades elicítadas por medições de exercícios *purple team* e de telemetria da planta, atualizando-as de forma bayesiana conforme as evidências se acumulam. Segundo, *modelagem setorial*: elevar o grafo de uma planta para uma rede de montadoras, fornecedores e plataformas compartilhadas com acoplamento *just-in-time* explícito, único nível em que a classe de eventos Kojima, CDK e JLR pode ser precificada. Terceiro, *instanciação viva*: derivar arestas de dados de inventário de ativos e de fluxos de rede em vez de elicitação, de modo que o modelo acompanhe a planta à medida que ela muda. Quarto, *validação em bancada*: executar os caminhos mais bem ranqueados contra uma linha física ou um gêmeo digital para medir os parâmetros que este artigo precisou elicitar. O artefato que acompanha este artigo [11] está estruturado de modo que cada uma dessas extensões seja um acréscimo ao *pipeline* existente, e não uma reescrita.

## DISPONIBILIDADE DO ARTEFATO

O modelo, o corpus de incidentes com as fontes, o *pipeline* de experimentos, as figuras e a suíte de testes estão disponíveis em <https://github.com/rikosoo/InfraCriticalCar>. A implementação usa apenas a biblioteca padrão do Python; `python3experiments/run_all.py` regenera todas as tabelas, figuras e números reportados neste artigo, e `pytest` executa a suíte de testes.

## APÊNDICE

### APÊNDICE: PARÂMETROS SELECIONADOS DO MODELO

As tables V to VII reportam integralmente os resultados de cenário, de portfólio guloso e de necessidade de controles. A lista completa de arestas, com  $p$ ,  $\delta$ , esforço, técnica, controles aplicáveis e evidência de incidentes de apoio por passo, está em `capm/architecture.py` no artefato, e os parâmetros de controle em `capm/controls.py`.

O modelo de consequência usa distribuições triangulares de parada com modas de 120 horas para parada de produção e 168 horas para consequência de segurança, uma taxa de perda de US\$ 1,05 milhão por hora de produção parada e custos fixos de resposta com modas de US\$ 25, 90, 150, 40 e 25 milhões para parada de produção, degradação de qualidade, segurança, roubo de dados de engenharia e vazamento de dados pessoais, respectivamente. A travessia da infraestrutura de backup multiplica a duração amostrada da parada por 1,8; a da plataforma de gestão de *endpoints* por 1,25; e a do controlador de domínio OT por 1,15.

## REFERÊNCIAS

- [1] International Organization for Standardization, “ISO/SAE 21434: Road vehicles — cybersecurity engineering,” ISO, Tech. Rep., 2021.
- [2] United Nations Economic Commission for Europe, “UN regulation no. 155 — uniform provisions concerning the approval of vehicles with regards to cyber security and cyber security management system,” UNECE, Tech. Rep., 2021.
- [3] International Electrotechnical Commission, “IEC 62443-3-2: Security for industrial automation and control systems — security risk assessment for system design,” IEC, Tech. Rep., 2020.
- [4] —, “IEC 62443-3-3: Security for industrial automation and control systems — system security requirements and security levels,” IEC, Tech. Rep., 2013.
- [5] K. Stouffer, M. Pease, C. Tang, T. Zimmerman, V. Pillitteri, S. Lightman, A. Hahn, S. Saravia, A. Sherule, and M. Thompson, “Guide to operational technology (OT) security,” National Institute of Standards and Technology, Tech. Rep. NIST SP 800-82r3, 2023.
- [6] T. J. Williams, “The Purdue enterprise reference architecture,” *Computers in Industry*, vol. 24, no. 2–3, pp. 141–158, 1994.
- [7] “Toyota cyberattack: Production to restart in Japan after attack on Kojima Industries,” CNN Business, <https://www.cnn.com/2022/03/01/business/toyota-japan-cyberattack-production-restarts-intl-hnk>, 2022, accessed 16 September 2026.
- [8] “Toyota halts production across Japan after ransomware attack,” Infosecurity Magazine, <https://www.infosecurity-magazine.com/news/toyota-production-japan-ransomware/>, 2022, accessed 16 September 2026.
- [9] Cyber Monitoring Centre, “Statement on the Jaguar Land Rover cyber incident,” <https://cybermonitoringcentre.com/2025/10/22/cyber-monitoring-centre-statement-on-the-jaguar-land-rovercyber-incident-october-2025/>, 2025, accessed 16 September 2026.
- [10] “Jaguar Land Rover attack to cost UK £1.9bn, say cyber monitors,” Computer Weekly, <https://www.computerweekly.com/news/366633395/Jaguar-Land-Rover-attack-to-cost-UK-19bn-say-cyber-monitors>, 2025, accessed 16 September 2026.
- [11] H. H. Stefanutti, “CAPM: Cyberattack path model for automotive manufacturing — reference implementation and incident corpus,” <https://github.com/rikosoo/InfraCriticalCar>, 2026.
- [12] M. J. Assante and R. M. Lee, “The industrial control system cyber kill chain,” SANS Institute, Tech. Rep., 2015.
- [13] R. Langner, “Stuxnet: Dissecting a cyberwarfare weapon,” *IEEE Security & Privacy*, vol. 9, no. 3, pp. 49–51, 2011.
- [14] J. Slay and M. Miller, “Lessons learned from the Maroochy water breach,” *Critical Infrastructure Protection, IFIP*, vol. 253, pp. 73–82, 2007.
- [15] D. U. Case, “Analysis of the cyber attack on the Ukrainian power grid,” Electricity Information Sharing and Analysis Center (E-ISAC) and SANS, Tech. Rep., 2016.
- [16] K. E. Hemsley and R. E. Fisher, “History of industrial control system cyber incidents,” Idaho National Laboratory, Tech. Rep. INL/CON-18-44411, 2018.
- [17] C. Phillips and L. P. Swiler, “A graph-based system for network-vulnerability analysis,” in *Proceedings of the 1998 Workshop on New Security Paradigms*. ACM, 1998, pp. 71–79.
- [18] O. Sheyner, J. Haines, S. Jha, R. Lippmann, and J. M. Wing, “Automated generation and analysis of attack graphs,” in *Proceedings of the IEEE Symposium on Security and Privacy*, 2002, pp. 273–284.
- [19] X. Ou, S. Govindavajhala, and A. W. Appel, “MulVAL: A logic-based network security analyzer,” in *Proceedings of the 14th USENIX Security Symposium*, 2005.
- [20] L. Wang, T. Islam, T. Long, A. Singhal, and S. Jajodia, “An attack graph-based probabilistic security metric,” *Data and Applications Security XXII, LNCS*, vol. 5094, pp. 283–296, 2008.
- [21] B. Kordy, L. Piètre-Cambacédès, and P. Schweitzer, “DAG-based attack and defense modeling: Don’t miss the forest for the attack trees,” *Computer Science Review*, vol. 13–14, pp. 1–38, 2014.
- [22] H. S. Lallie, K. Debattista, and J. Bal, “A review of attack graph and attack tree visual syntax in cyber security,” *Computer Science Review*, vol. 35, p. 100219, 2020.
- [23] K. Zenitani, “Attack graph analysis: An explanatory guide,” *Computers & Security*, vol. 126, p. 103081, 2023.
- [24] E. J. Byres, M. Franz, and D. Miller, “The use of attack trees in assessing vulnerabilities in SCADA systems,” *Proceedings of the International Infrastructure Survivability Workshop*, 2004.
- [25] C.-W. Ten, C.-C. Liu, and G. Manimaran, “Vulnerability assessment of cybersecurity for SCADA systems,” *IEEE Transactions on Power Systems*, vol. 23, no. 4, pp. 1836–1846, 2008.
- [26] A. Hahn and M. Govindarasu, “Cyber attack exposure evaluation framework for the smart grid,” *IEEE Transactions on Smart Grid*, vol. 2, no. 4, pp. 835–843, 2011.
- [27] S. Kriaa, L. Piètre-Cambacédès, M. Bouissou, and Y. Halgand, “A survey of approaches combining safety and security for industrial control systems,” *Reliability Engineering & System Safety*, vol. 139, pp. 156–178, 2015.
- [28] Y. Cherdantseva, P. Burnap, A. Blyth, P. Eden, K. Jones, H. Soulsby, and K. Stoddart, “A review of cyber security risk assessment methods for SCADA systems,” *Computers & Security*, vol. 56, pp. 1–27, 2016.
- [29] J. Freund and J. Jones, *Measuring and Managing Information Risk: A FAIR Approach*. Butterworth-Heinemann, 2014.
- [30] D. W. Hubbard and R. Seiersen, *How to Measure Anything in Cybersecurity Risk*. Wiley, 2016.
- [31] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and philosophy,” The MITRE Corporation, Tech. Rep. MP180360R1, 2018.
- [32] O. Alexander, M. Belisle, and J. Steele, “MITRE ATT&CK for industrial control systems: Design and philosophy,” The MITRE Corporation, Tech. Rep., 2020.
- [33] International Electrotechnical Commission, “IEC 62443-2-4: Security program requirements for IACS service providers,” IEC, Tech. Rep., 2015.
- [34] European Parliament and Council, “Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the union (NIS 2),” Official Journal of the European Union L 333/80, 2022.
- [35] Cybersecurity and Infrastructure Security Agency, “Critical manufacturing sector,” <https://www.cisa.gov/topics/critical-infrastructure-security-and-resilience/critical-infrastructure-sectors/critical-manufacturing-sector>, 2024, accessed 16 September 2026.
- [36] “Throwback attack: WannaCry ransomware takes Renault-Nissan plants offline,” Control Engineering, <https://www.controleng.com/throwback-attack-wannacry-ransomware-takes-renault-nissan-plants-offline/>, 2022, accessed 16 September 2026.
- [37] “European car plants halted by WannaCry ransomware attack,” NBC News, <https://www.nbcnews.com/business/autos/european-car-plants-halted-wannacry-ransomware-attack-n759496>, 2017, accessed 16 September 2026.
- [38] “Hospital-busting hacker crew may be behind ransomware attack that made Honda halt car factories,” The Register, [https://www.theregister.com/2020/06/09/honda\\_ransomware\\_snake\\_ekans\\_malware/](https://www.theregister.com/2020/06/09/honda_ransomware_snake_ekans_malware/), 2020, accessed 16 September 2026.
- [39] “Automotive giant DENSO hit by new Pandora ransomware gang,” BleepingComputer, <https://www.bleepingcomputer.com/news/security/automotive-giant-denso-hit-by-new-pandora-ransomware-gang/>, 2022, accessed 16 September 2026.
- [40] “Bridgestone Americas confirms ransomware attack, LockBit leaks data,” BleepingComputer, <https://www.bleepingcomputer.com/news/security/bridgestone-americas-confirms-ransomware-attack-lockbit-leaks-data/>, 2022, accessed 16 September 2026.
- [41] “LockBit ransomware claims attack on Continental automotive giant,” BleepingComputer, <https://www.bleepingcomputer.com/news/security/lockbit-ransomware-claims-attack-on-continental-automotive-giant/>, 2022, accessed 16 September 2026.

Tabela V  
RESULTADOS DAS CAMPANHAS E PERDA ANUAL ESPERADA POR CENÁRIO DE CONTROLES, PERFIL DE RANSOMWARE DE GRANDE PORTE.

| Cenário                           | <i>P</i> (impacto) | <i>P</i> (parada) | Parada (h) | Perda anual (M\$) | Custo |
|-----------------------------------|--------------------|-------------------|------------|-------------------|-------|
| S0 linha de base                  | 0.0981             | 0.0770            | 24.8       | 47.57             | 0     |
| S1 identidade primeiro            | 0.0977             | 0.0757            | 24.4       | 47.00             | 23    |
| S2 zonas e conduits IEC 62443     | 0.0973             | 0.0758            | 24.4       | 47.01             | 25    |
| S3 cadeia de fornecimento e nuvem | 0.1037             | 0.1027            | 33.2       | 60.09             | 19    |
| S4 detectar e recuperar           | 0.1014             | 0.0549            | 4.5        | 16.86             | 24    |
| S5 programa completo              | 0.0238             | 0.0047            | 0.4        | 3.37              | 91    |

Tabela VI  
PORTFÓLIO DE CONTROLES CONSTRUÍDO DE FORMA GULOSA POR CUSTO-EFETIVIDADE PARA O PERFIL DE RANSOMWARE DE GRANDE PORTE.

| Passo | Controle | Nome                                                                     | Perda após (M\$) | Δ/custo |
|-------|----------|--------------------------------------------------------------------------|------------------|---------|
| 1     | C08      | Backups imutáveis, offline e testados (TI e OT)                          | 29.23            | 3.67    |
| 2     | C17      | Resiliência operacional: buffers, fallback manual e modo degradado       | 17.31            | 1.70    |
| 3     | C11      | Governança de SaaS e de tokens OAuth                                     | 16.86            | 0.11    |
| 4     | C10      | Gestão de superfície de ataque e correção acelerada de serviços expostos | 15.70            | 0.23    |
| 5     | C14      | Garantia de segurança de fornecedores e telemetria contratual            | 7.41             | 1.38    |
| 6     | C02      | Acesso condicional e conformidade de dispositivo                         | 5.52             | 0.47    |

[42] “Elon Musk confirmed Russian’s plans to extort Tesla,” BleepingComputer, <https://www.bleepingcomputer.com/news/security/elon-musk-confirmed-russians-plans-to-extort-tesla/>, 2020, accessed 16 September 2026.

Technology, Tech. Rep. NIST CSWP 29, 2024.

[43] “Toyota: Car location data of 2 million customers exposed for ten years,” BleepingComputer, <https://www.bleepingcomputer.com/news/security/toyota-car-location-data-of-2-million-customers-exposed-for-ten-years/>, 2023, accessed 16 September 2026.

[44] “Customer data from 800,000 electric cars and owners exposed online,” BleepingComputer, <https://www.bleepingcomputer.com/news/security/customer-data-from-800-000-electric-cars-and-owners-exposed-online/>, 2024, accessed 16 September 2026.

[45] “How did the auto dealer outage end? CDK almost certainly paid a \$25 million ransom,” CNN Business, <https://edition.cnn.com/2024/07/11/business/cdk-hack-ransom-twenty-five-million-dollars/>, 2024, accessed 16 September 2026.

[46] “Stellantis production halted after attack on auto parts giant Yanfeng,” BleepingComputer, <https://www.bleepingcomputer.com/news/security/stellantis-production-halted-after-attack-on-auto-parts-giant-yanfeng/>, 2023, accessed 16 September 2026.

[47] “Automaker giant Stellantis confirms data breach after Salesforce hack,” BleepingComputer, <https://www.bleepingcomputer.com/news/security/automaker-giant-stellantis-confirms-data-breach-after-salesforce-hack/>, 2025, accessed 16 September 2026.

[48] “Toyota discloses data breach after access key exposed on GitHub,” BleepingComputer, <https://www.bleepingcomputer.com/news/security/toyota-discloses-data-breach-after-access-key-exposed-on-github/>, 2022, accessed 16 September 2026.

[49] “MKS Instruments faces \$200 million loss after february ransomware attack,” BleepingComputer, <https://www.bleepingcomputer.com/news/security/mks-instruments-faces-200-million-loss-after-february-ransomware-attack/>, 2023, accessed 16 September 2026.

[50] National Institute of Standards and Technology, “The NIST cybersecurity framework (CSF) 2.0,” National Institute of Standards and

Tabela VII

NECESSIDADE DE CADA CONTROLE DENTRO DO PROGRAMA COMPLETO  
 $S_5$ : A PERDA ANUAL QUE RETORNA QUANDO APENAS AQUELE CONTROLE  
 É RETIRADO.

| Controle | Nome                                                               | $\Delta$ perda (M\$) |
|----------|--------------------------------------------------------------------|----------------------|
| C11      | Governança de SaaS e de tokens OAuth                               | 12.86                |
| C14      | Garantia de segurança de fornecedores e telemetria contratual      | 11.83                |
| C07      | Detecção em endpoint com resposta monitorada 24/7                  | 1.57                 |
| C16      | Gestão de postura de nuvem e de exposição de dados                 | 1.34                 |
| C17      | Resiliência operacional: buffers, fallback manual e modo degradado | 1.08                 |
| C08      | Backups imutáveis, offline e testados (TI e OT)                    | 0.62                 |
| C02      | Acesso condicional e conformidade de dispositivo                   | 0.00                 |
| C03      | Camadas administrativas e estações de acesso privilegiado          | 0.00                 |
| C04      | Acesso remoto de fornecedores intermediado e just-in-time          | 0.00                 |
| C06      | Lista de permissão de aplicações e controle de mídia em hosts OT   | 0.00                 |